

Botium Toys: Scope, goals, and risk assessment report

Practical portfolio for Course 2: Google Cybersecurity

Summary

Botium Toys does not have all proper control categories (Physical, Administrative, Technical) and not fully compliant with U.S. and international regulations and standards. Here are the detailed checklists with a risk score of 8 out of 10 (1 is safe while 10 is critical risk):

Controls Assessment checklist

Yes	No	Control
	/	Least Privilege
	/	Disaster recovery plans
	/	Password policies
	/	Separation of duties
/		Firewall
	/	Intrusion detection system (IDS)
	/	Backups
/		Antivirus software
	/	Manual monitoring, maintenance, and intervention for legacy systems
/		Encryption
	/	Password management system
/		Locks (offices, storefront, warehouse)
/		Closed-circuit television (CCTV) surveillance
/		Fire detection/prevention (fire alarm, sprinkler system, etc.)

Does Botium Toys currently adhere to this compliance best practice?

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
/		Only authorized users have access to customers' credit card information.
/		Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
	/	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
	/	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
	/	E.U. customers' data is kept private/secured.
/		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
	/	Ensure data is properly classified and inventoried.
/		Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
	/	User access policies are established.
	/	Sensitive data (PII/SPII) is confidential/private.
/		Data integrity ensures the data is consistent, complete, accurate, and has been validated.
/		Data is available to individuals authorized to access it.

Recommendations

To provide the needed compliance requirements with proper implementation, the department would communicate to the IT manager and await response when they communicate to the stakeholders the needed implementations. Here are the recommendations that must happen:

For Administrative controls, access control of PII and other data from customers (users) must be prioritized since Botium Toys employees can access them. Therefore, the department administrators must enforce the Principle Least of Privilege for employees the necessary accessible tools suited for their role responsibilities. Although privacy policies, procedures, and processes are enforced, the lack of disaster recovery plans must be implemented so backups are in place. Therefore, the company must propose a DRP and BCP (if there is one) and have workshops, simulations, and meetings annually to reinforce awareness.

For Technical controls, necessary applications such as firewall, security policies, and antivirus are setup and configured. Intrusion Detection System is not installed and must be implemented asap. Password policy must be renewed too since some employees' passwords do not meet the minimum password complexity requirements (easy-to-guess passwords can be hacked).

For Physical controls, there are no critical implementations since the offices, store fronts, and warehouses have locks, CCTV surveillance, fire detection, and prevention systems. One requirement that shall be implemented is the scheduled patch updates and maintenance of legacy systems (servers, workstations, etc.) since the company's methods are not stated.

Overall, here are the recommendations that must be implemented for Botium Toys to be secured. This is my input and this document can be improved as a baseline for future implementations.